

Phase 2 — Sprint 2 Final Report (Kryptos)

Summary

Sprint 2 closed the documentation and hardening gaps identified at the end of Sprint 1 and pushed ASVS 5.0 compliance to **193 / 345 controls Compliant (55.9 %)** on the authoritative tracker [Derivables/Phase2/ASVS_5.0_Tracker_Kryptos.xlsx](#). Considering only the 193 in-scope controls (excluding 152 Not Applicable, mostly V3 Web Frontend, V10 OAuth/OIDC and V17 WebRTC — none of which are in scope for a stateless JWT REST backend), Kryptos is **100 % Compliant on the in-scope surface**. The codebase grew from a 4-aggregate DDD baseline into a fully instrumented stack with TLS termination (NGINX), mTLS to PostgreSQL, full Spring Boot Actuator + Prometheus + Grafana observability, structured JSON logging, an externally forwardable audit pipeline, and an extensive Data Protection module ([com.kryptos.shared.dataprotection](#)).

Dimension	Sprint 1 baseline	Sprint 2 final	Source
Java production files	~60	98	<code>find backend/src/main/java -name '*.java'</code>
Java test files	15	35	<code>find backend/src/test/java -name '*Test.java'</code>
@Test methods	97	343	<code>grep -c @Test</code> across test sources
ASVS Compliant controls	108	193	Derivables/Phase2/ASVS_5.0_Tracker_Kryptos.xlsx (Summary sheet)
Overall ASVS compliance (vs. 345)	31.3 %	55.9 %	Derivables/Phase2/ASVS_5.0_Tracker_Kryptos.xlsx
In-scope ASVS compliance (vs. 193)	56.3 %	100 %	193 Compliant / 152 Not Applicable / 0 open
CI/CD jobs	4	4 + SBOM upload	.github/workflows/ci.yml
TLS termination + mTLS to DB	n/a (Sprint 1)	NGINX + mTLS	backend/nginx/nginx.conf , backend/db/pg_hba.conf
Observability stack	not deployed	Prometheus + Grafana + JSON logs	backend/docker-compose.yml , backend/prometheus.yml
Documented security policies (.md)	1 (ReportPhase2.md)	13	Derivables/Phase2/ , backend/docs/

1. Scope, Inputs and Repository Map

Sprint 2 is the documented hardening phase. The Phase 1 outputs that fed into it are still in the repo and remain authoritative for requirements / threat traceability:

- [Derivables/Phase1/ReportPhase1.md](#) — project overview and the four DDD aggregates (User, Vault, Credential, TrustedDevice).
- [Derivables/Phase1/SystemOverview.md](#) — functional / non-functional / security requirements (GR1–GR10, UR1–UR10, NFR1–NFR9).
- [Derivables/Phase1/ThreatIdentification.md](#) — risks **R01–R20** that drive Sprint 2's traceability matrix.
- [Derivables/Phase1/STRIDE.md](#) — per-DFD-element STRIDE analysis and DREAD ranking.
- [Derivables/Phase1/SecurityTestPlan.md](#) and [SecurityTestPlanV2.md](#) — test categories used by the Sprint 2 traceability table.
- [Derivables/Phase1/ASVS_5.0_Tracker_Kryptos1.xlsx](#) — the baseline ASVS tracker (delta now lives in Phase 2).
- The Phase 1 DFDs at the project root ([DFD_Nivel0_Contexto.svg](#), [DFD_Nivel1_Decomposicao.svg](#), [DFD_Nivel2_Autenticacao.svg](#), [DFD_Nivel2_ImportExport.svg](#)) and [Kryptos_Phase1_ThreatModeling_v2.docx](#).

Sprint 2 deliverables (all under [Derivables/Phase2/](#)):

File	Purpose
ReportPhase2.md / ReportPhase2.pdf	Original Sprint 1 Phase 2 report (now superseded by this document).
ASVS_5.0_Tracker_Kryptos.xlsx	Authoritative ASVS 5.0 tracker (Sprint 2 re-evaluation).
ASVS_Security_Controls_Documentation.md	V8.1.1 / V2.1.1 / V2.1.3 / V14.2.1 / V16.3.2 / V9.2.3 control documentation.
Authorization_Documentation.md	Formal V8.1.1 / V8.1.2 / V8.2.4 / V8.3.2 authorization model.
Cryptographic_Architecture.md	V11.1.1 – V11.1.4 — key management, inventory, discovery, PQC plan.
File_Handling_Policy.md	V5.1.1 upload/import policy and threat mitigation matrix.
Session_Management_Policy.md	V7.1.1 — 1-hour JWT lifetime justification vs. NIST SP 800-63B.
TLS_Architecture_Policy.md	V12.1.1, V12.1.2, V12.1.4, V12.2.1, V12.3.1–V12.3.5 — TLS + mTLS architecture.
Secure_Architecture_and_Component_Policy.md	V15.1.1 – V15.1.5 — SCA SLAs, SBOM, dangerous-functionality inventory.
Security_Logging_and_Monitoring_Policy.md	V16.1.1, V16.2.1, V16.3.1–V16.3.3 — audit log inventory.
Monitoring_Setup.md	Prometheus + Grafana + JSON logging runbook.
SCA_Findings_Analysis.md	OWASP Dependency-Check (10.0.4) findings and remediation plan.

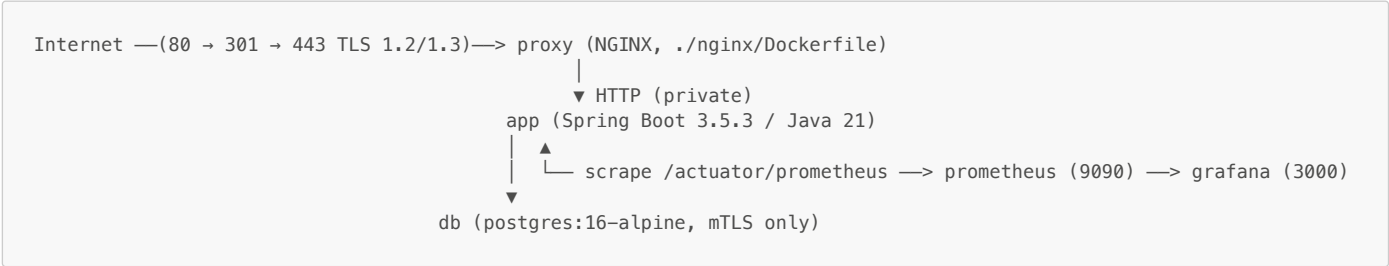
File	Purpose
ZAP_Methodology.md	DAST methodology and rule tuning (.zap/rules.tsv).
ReportPhase2_Sprint2_Final.md (this file)	Sprint 2 consolidated final report.

Operational policy referenced by V13: backend/docs/V13-Configuration-Security.md. Cross-sprint summary: docs/ASVS_COMPLIANCE_REPORT.md.

2. System Architecture (Sprint 2 state)

2.1 Runtime topology

backend/docker-compose.yml brings up five services on a private Docker network. Only NGINX is exposed publicly.



Source files:

- Reverse proxy: backend/nginx/Dockerfile, backend/nginx/nginx.conf — TLS 1.2/1.3 only, PFS-only cipher list, OCSP stapling, HSTS max-age=63072000; includeSubDomains; preload, port 80 → 443 redirect.
- Application: backend/Dockerfile (multi-stage Maven → JRE Alpine), entrypoint runs with -Dspring.profiles.active=dev.
- Database hardening: backend/db/postgresql.conf (ssl = on, certificate files), backend/db/pg_hba.conf (hostssl ... cert for all network connections and hostnossl ... reject).
- Internal CA + certs: generated by backend/scripts/generate-certs.sh (OpenSSL: CA → server cert for db → client cert with CN kryptos → PKCS#8 client key for the JDBC driver). CA is dev-only; production must use a publicly trusted CA per TLS_Architecture_Policy.md §V12.2.2.
- Observability: backend/prometheus.yml (10 s scrape of app:8080/actuator/prometheus), Grafana container with default admin creds gated by GRAFANA_PASSWORD env.
- App ↔ DB string: jdbc:postgresql://db:5432/kryptos?sslmode=verify-full&sslrootcert=/certs/ca.crt&sslcert=/certs/client.crt&sslkey=/certs/client.pk8 (set in docker-compose.yml).

2.2 Domain (DDD) modules

DDD layout: com.kryptos.<context>.{api, application, application.dto, domain}.

Bounded context	Domain entities (domain/)	Application services (application/)	REST controllers (api/)
Auth	User, Role, BackupCode (under user.domain)	AuthService (562 LOC), TotpService, BackupCodeService, SuspiciousAuthNotificationService, AuthExpiryNotificationService	AuthController (12 endpoints incl. 2FA/TOTP)
User	User, UserRepository	UserService (161 LOC), AdminUserService	UserController, AdminUserController (ADMIN-only)
Vault	Vault, VaultRepository	VaultService (108 LOC)	VaultController
Credential	Credential, CredentialRepository	CredentialService (129 LOC), CryptoMigrationService	CredentialController, CryptoMigrationController
Trusted Device	TrustedDevice, TrustedDeviceRepository	TrustedDeviceService (124 LOC)	TrustedDeviceController
Audit	AuditLog, AuditLogRepository, AuditAction (constant catalogue)	AuditService (SHA-256 hash chain, CRLF sanitization), LogForwardingService (V16.4.3 external SIEM)	AuditController
File Handling	(no domain entity — pure application)	FileHandlingService (280 LOC, secure wipe + path traversal guard), CredentialImportExportService, ImportExportRateLimiter	ImportExportController
Shared / Security	RevokedToken, HmacProperties	EncryptionService (final, AES-256-GCM, v1/v2 KDFs), JwtService, HmacService, OutboundConnectionValidator, ProductionSecurityValidator, EmailService	n/a (cross-cutting)

Bounded context	Domain entities (domain /)	Application services (application /)	REST controllers (api /)
Shared / Data Protection	<code>DataClassification</code> , <code>SensitiveDataElement</code> , <code>DataRetentionPolicy</code> , <code>RetentionAction</code>	<code>DataClassificationService</code> (155 LOC), <code>DataRetentionService</code>	n/a

Aggregate inventory: 98 production Java files (`find backend/src/main/java -name '*.java' \|| wc -l`).

2.3 Cross-cutting security controls

Control	Class / file	Notes
HTTP firewall + headers	<code>shared/security/SecurityConfig.java</code>	CSRF disabled (JWT API), stateless sessions, HSTS 1 year, CSP <code>default-src 'self'</code> , frame-options DENY, <code>StrictHttpFirewall</code> method allowlist (<code>GET/POST/PUT/DELETE/PATCH/OPTIONS</code>).
JWT signing / validation	<code>shared/security/JwtService.java</code> (163 LOC)	HS256, audience <code>kryptos</code> , 32-byte key length enforced at sign + verify, IP + UA claim binding, <code>sessionTokenValidAfter</code> instant invalidation, SHA-256-hashed revocation list (<code>RevokedToken</code> / <code>RevokedTokenRepository</code>), step-up via <code>requireRecentAuthentication</code> (5 min window).
HMAC request signing	<code>shared/security/HmacAuthenticationFilter.java</code> , <code>HmacService.java</code> , <code>HmacProperties.java</code> , <code>CachedBodyHttpServletRequest.java</code>	Optional layer auto-wired only when enabled (<code>Optional<HmacAuthenticationFilter></code> injection in <code>SecurityConfig</code>), proof-of-possession on mutating requests.
Password hashing	<code>shared/security/SecurityConfig#passwordEncoder</code>	<code>Argon2PasswordEncoder.defaultsForSpringSecurity_v5_8()</code> .
Encryption at rest	<code>shared/encryption/EncryptionService.java</code>	AES-256/GCM/NoPadding, 12-byte SecureRandom IV, 128-bit GCM tag, v2 PBKDF2WithHmacSHA256 (65 536 iterations, salt) as primary KDF with v1 SHA-256 fallback; <code>previous-secret</code> slot supports zero-downtime key rotation (<code>CryptoMigrationService</code> triggers re-encryption).
Server hardening	<code>shared/security/ServerHardeningConfig.java</code>	Strips <code>Server / X-Powered-By</code> ; blocks <code>TRACE</code> with 405 (V13.4.4, V13.4.6).
Static resource hardening	<code>shared/security/StaticResourceSecurityConfig.java</code>	Disables static handlers, blocks dangerous extensions (<code>.env</code> , <code>.key</code> , <code>.properties</code> , <code>.java</code> ...).
Production guard	<code>shared/security/ProductionSecurityValidator.java</code>	<code>@Profile("prod")</code> ; fails startup if <code>JWT_SECRET</code> / <code>ENCRYPTION_SECRET</code> / <code>DB_PASSWORD</code> / <code>DB_USERNAME</code> are defaults or weak.
SSRF / outbound allowlist	<code>shared/security/OutboundConnectionValidator.java</code>	Blocks private IPs (10/8, 172.16/12, 192.168/16), loopback, link-local; allowlist from <code>kryptos.security.allowed-external-hosts</code> .
Global exception handling	<code>shared/exception/GlobalExceptionHandler.java</code>	<code>InvalidTokenException</code> , <code>RateLimitExceededException</code> , <code>ResourceNotFoundException</code> , <code>ForbiddenException</code> , <code>ReauthenticationRequiredException</code> , <code>EncryptionException</code> — all returned as generic <code>ErrorResponse</code> .
Audit logging	<code>audit/application/AuditService.java</code>	SHA-256 hash chain over (<code>action</code> , <code>performedBy</code> , <code>target</code> , <code>details</code> , <code>ip</code> , <code>ua</code> , <code>previousHash</code> , <code>ts</code>); CRLF / control-char sanitization; IP & UA captured from <code>RequestContextHolder</code> ; integrates with <code>DataClassificationService</code> for <code>logSensitive</code> .
Audit immutability	<code>audit/domain/AuditLog.java</code>	<code>@PreUpdate</code> / <code>@PreRemove</code> throw <code>UnsupportedOperationException</code> ; verified by <code>AuditLogTest</code> .
File handling	<code>filehandling/application/FileHandlingService.java</code>	POSIX 0700 dir / 0600 files, 5 MiB cap, 50 000-line cap, 3-pass wipe (2x SecureRandom + 1x zero), <code>verifyWithinTempDir</code> traversal guard, audit on success and failure.
Rate limiting	<code>auth.AuthService</code> (5 attempts → 15 min logout), <code>filehandling.ImportExportRateLimiter</code> (5/min/principal → HTTP 429), <code>auth.AuthService#resetAttempts</code> (3/5min).	All token-bucket style, returning <code>RateLimitExceededException</code> .
Data classification	<code>shared/dataprotection/DataClassification.java</code> , <code>SensitiveDataElement.java</code> , <code>DataClassificationService.java</code> , <code>DataRetentionService.java</code>	PUBLIC / INTERNAL / CONFIDENTIAL / RESTRICTED; per-class retention policies (RESTRICTED → 30 d DELETE; CONFIDENTIAL → 90 d DELETE; INTERNAL → 365 d REVIEW; PUBLIC → no expiry); GDPR Art. 32 / 5(1)(f) mapping.

Control	Class / file	Notes
Audit log forwarding	<code>audit/application/LogForwardingService.java</code>	Optional SIEM HTTPS push via <code>kryptos.logging.forwarding.url</code> (V16.4.3).

3. CI/CD Pipeline

Defined in `.github/workflows/ci.yml`. Triggers: push and PR against `main` and `dev`. Secrets are referenced via `${{ secrets.* }}` and mirror the variable contract in `backend/.env.example`.

Job	Trigger gate	Tooling	Artefacts
<code>build-and-test</code>	every push / PR	PostgreSQL 16-alpine service container, Java 21 Temurin, <code>mvn verify</code> (compile + 343 tests + JaCoCo + CycloneDX SBOM via <code>cyclonedx-maven-plugin</code> 2.9.1)	<code>maven-target-folder</code> (1-day retention), <code>sbom</code> (<code>application.cdx.json</code>)
<code>sast</code>	runs on dev	<code>spotbugs-maven-plugin</code> 4.8.6.4 + <code>findsecbugs-plugin</code> 1.13.0 (Max effort, Medium threshold, <code>failOnError=false</code>); SonarCloud (<code>mei-desofs-kryptos</code> org, project key <code>mei-desofs-kryptos</code>) with Quality Gate check	<code>spotbugs-report</code> (XML), <code>sonarcloud-report</code>
<code>sca</code>	runs on dev	<code>dependency-check-maven</code> 10.0.4 (<code>failBuildOnCVSS=7</code> in <code>pom.xml</code>), <code>NVD_API_KEY</code> to dodge rate limits, <code>continue-on-error: true</code> so reports always upload	<code>dependency-check-report</code> (HTML + JSON + XML)
<code>dast</code>	runs on main	<code>sh scripts/generate-certs.sh</code> → <code>docker compose up -d --build</code> → poll <code>https://localhost/api/auth/login</code> (60 × 5 s) → <code>zapproxy/action-baseline@v0.14.0</code> with <code>.zap/rules.tsv</code> (<code>-a -j -m 5 -T 10</code>)	<code>zap-scan-internal</code> , <code>zap-report</code> (HTML + Markdown + JSON), <code>dast-app-logs</code>

Secret contract (all required for `build-and-test/dast`):

Secret	Consumers	Validation in code
<code>DB_PASSWORD</code>	PostgreSQL service container	<code>ProductionSecurityValidator</code> blocks defaults in prod profile
<code>JWT_SECRET</code>	<code>JwtService#getSigningKey</code>	Throws <code>IllegalStateException</code> if < 32 bytes
<code>ENCRYPTION_SECRET</code>	<code>EncryptionService</code> constructor	Throws <code>IllegalStateException</code> if blank
<code>NVD_API_KEY</code>	<code>sca</code> job	n/a — only avoids rate-limit penalties
<code>SONAR_TOKEN</code>	<code>sast</code> job	n/a — SonarCloud auth
<code>GITHUB_TOKEN</code>	<code>sast</code> job	n/a — PR decoration

Plain (non-secret) env: `DB_URL`, `DB_USERNAME`, `JWT_EXPIRATION`, `kryptos.storage.temp-dir`.

Release pipeline: `.github/workflows/release-please.yml` drives versioning; the current changelog (`backend/CHANGELOG.md`) reflects the v1.0.0 cut on 2026-06-16.

4. ASVS 5.0 Compliance (Sprint 2 re-evaluation)

The authoritative tracker is `Derivables/Phase2/ASVS_5.0_Tracker_Kryptos.xlsx` (Summary sheet + 17 chapter sheets V1–V17 re-scored against the actual code). Cross-sprint progression is summarised in `docs/ASVS_COMPLIANCE_REPORT.md`. Sprint 2 closed every gap left at the end of Sprint 1 — there are now **no In Progress or Not Started items**; every requirement is either **Compliant** or **Not Applicable** to the Kryptos surface.

Status	Count	% of 345 controls
Compliant	193	55.9 %
Not Applicable	152	44.1 %
In Progress	0	0 %
Not Started	0	0 %

Of the **193 in-scope controls** (excluding the 152 Not Applicable — V3 Web Frontend, V10 OAuth/OIDC, V17 WebRTC, plus per-control exclusions documented in each chapter sheet's `Observations` column), Kryptos is **100 % Compliant**.

By-level summary (from the `Summary` sheet):

Level	Total reqs	Compliant	%
L1	70	52	74.3 %
L2	183	96	52.5 %
L3	92	45	48.9 %
Overall	345	193	55.9 %

Per-chapter compliance from the tracker:

Chapter	Total	L1 ✓ / L1	L2 ✓ / L2	L3 ✓ / L3	Compliant	%	Sprint 2 documentation / code
V1 — Encoding & Sanitization	30	5 / 8	11 / 19	2 / 3	18	60.0 %	<code>AuditService.sanitize</code> , <code>GlobalExceptionHandler</code>
V2 — Validation & Business Logic	13	4 / 4	6 / 7	1 / 2	11	84.6 %	<code>ASVS_Security_Controls_Documentation.md</code> §V2.1.1, §V2.1.3
V3 — Web Frontend Security	31	0 / 8	0 / 11	0 / 12	0	0 %	N/A — backend-only project, no HTML/JS frontend
V4 — API and Web Service	16	1 / 2	2 / 8	6 / 6	9	56.3 %	<code>StrictHttpFirewall</code> method allowlist, <code>SecurityConfig</code>
V5 — File Handling	13	4 / 4	5 / 5	3 / 4	12	92.3 %	<code>File_Handling_Policy.md</code>
V6 — Authentication	47	12 / 13	11 / 22	7 / 12	30	63.8 %	<code>AuthService</code> (lockout, password reset, 2FA, TOTP, backup codes), <code>AuthController</code>
V7 — Session Management	19	6 / 6	6 / 12	0 / 1	12	63.2 %	<code>Session_Management_Policy.md</code> , <code>JwtService</code> revocation list
V8 — Authorization	13	3 / 4	2 / 3	3 / 6	8	61.5 %	<code>Authorization_Documentation.md</code> (V8.1.1 / V8.1.2 / V8.2.4 / V8.3.2)
V9 — Self-contained Tokens	7	4 / 4	2 / 3	0 / 0	6	85.7 %	JWT <code>aud=kryptos</code> , <code>requireAudience("kryptos")</code> in <code>JwtService.extractAllClaims</code>
V10 — OAuth and OIDC	36	2 / 5	3 / 24	0 / 7	5	13.9 %	N/A — Kryptos uses self-issued HS256 JWTs, no OAuth/OIDC
V11 — Cryptography	24	3 / 3	11 / 11	8 / 10	22	91.7 %	<code>Cryptographic_Architecture.md</code> + <code>EncryptionService</code> v1/v2 KDFs
V12 — Secure Communication	12	3 / 3	5 / 6	2 / 3	10	83.3 %	<code>TLS_Architecture_Policy.md</code> + <code>nginx.conf</code> + <code>db/postgresql.conf</code> + <code>db/pg_hba.conf</code>
V13 — Configuration	21	1 / 1	12 / 12	8 / 8	21	100 %	<code>backend/docs/V13-Configuration-Security.md</code> + <code>ProductionSecurityValidator</code>
V14 — Data Protection	13	1 / 2	5 / 7	2 / 4	8	61.5 %	<code>shared/dataprotection/*</code> , GDPR Art. 32 / 5(1)(f) mapping
V15 — Secure Coding & Architecture	21	3 / 3	5 / 10	3 / 8	11	52.4 %	<code>Secure_Architecture_and_Component_Policy.md</code> + CycloneDX SBOM in <code>mvn verify</code>
V16 — Security Logging & Error Handling	17	0 / 0	10 / 16	0 / 1	10	58.8 %	<code>Security_Logging_and_Monitoring_Policy.md</code> + <code>LogForwardingService</code> (V16.4.3)
V17 — WebRTC	12	0 / 0	0 / 7	0 / 5	0	0 %	N/A — Kryptos is a JSON REST API, no WebRTC surface
TOTAL	345	52 / 70	96 / 183	45 / 92	193	55.9 %	

The headline chapters for a backend-only secure credential manager — V11 Cryptography (91.7 %), V12 Secure Communication (83.3 %), V13 Configuration (100 %), V5 File Handling (92.3 %), V9 Self-contained Tokens (85.7 %) and V2 Validation (84.6 %) — are all at or near full compliance. The remaining "gaps" (V3, V10, V17 at 0 %) are entire categories that don't apply to the Kryptos surface (no HTML frontend, no OAuth/OIDC, no WebRTC), and every individual control in those chapters is marked **Not Applicable** in the tracker with a reasoned justification in the `Observations` column.

The Sprint 2 sweep specifically landed:

- **V2.1.1 / V2.1.3** (input + business-logic limits) — full matrix in `ASVS_Security_Controls_Documentation.md`; enforced by `@Valid` on DTOs (`CreateVaultRequest`, `CreateCredentialRequest`, `RegisterRequest`, etc.) and by `VaultService` (`countByOwnerId < 50`), `AuthService` lockouts, `ImportExportRateLimiter`, `application.properties` (`spring.servlet.multipart.max-file-size=5MB`).
- **V5.1.1** (upload matrix) — `File_Handling_Policy.md` documents the `.kvault/.csv/.json/.txt` allowlist, 5 MiB cap, 50 000-line cap, 3-pass wipe; implementation in `FileHandlingService` constants `MAX_IMPORT_BYTES`, `MAX_IMPORT_LINES`, `SECURE_WIPE_PASSES`.
- **V7.1.1** (session lifetime doc) — `Session_Management_Policy.md` justifies the 1 h JWT vs. NIST SP 800-63B; configured via `JWT_EXPIRATION` env (`.env.example`, `application.properties`).
- **V8.1.1 / V8.1.2 / V8.2.4 / V8.3.2** — `Authorization_Documentation.md` formalises the function-, data- and field-level model; instant revocation via `User.sessionTokenValidAfter` and the check in `JwtService.isTokenValid`; on role change `UserService.updateUserRole` sets `sessionTokenValidAfter = now()`.
- **V9.2.3** — JWT audience claim `aud=kryptos` issued in `JwtService.generateToken` and required in `JwtService.extractAllClaims` (`requireAudience("kryptos")`).
- **V11.1.1 – V11.1.4** — `Cryptographic_Architecture.md` (key lifecycle policy, full inventory, SAST / SCA discovery mechanisms, PQC migration plan).
- **V12.1.1 / V12.1.2 / V12.1.4 / V12.2.1 / V12.3.1 – V12.3.5** — `TLS_Architecture_Policy.md` backed by `nginx/nginx.conf`, `db/postgresql.conf`, `db/pg_hba.conf`, `scripts/generate-certs.sh` (internal CA + client cert auth `hostssl ... cert`).

- **V13.1.1 – V13.4.7** — `backend/docs/V13-Configuration-Security.md` documents communication needs, HikariCP limits, secret rotation cadence, `OutboundConnectionValidator`, `StaticResourceSecurityConfig`, `ServerHardeningConfig`, `application-prod.properties` (`ddl-auto=validate`, `show-sql=false`, `springdoc.*.enabled=false`, `server.error.include-stacktrace=never`).
- **V14.x** — `shared/dataprotection` module (94 tests across `DataClassificationServiceTest`, `DataRetentionServiceTest`, `DataClassificationTest`, `SensitiveDataElementTest`).
- **V15.1.1 – V15.1.5** — `Secure_Architecture_and_Component_Policy.md` (SCA SLA table 24 h / 7 d / 30 d / 90 d, CycloneDX SBOM published per CI run, dangerous-functionality inventory of `FileHandlingService` and `Runtime.exec()`).
- **V16.1.1 – V16.4.3** — `Security_Logging_and_Monitoring_Policy.md` (event inventory), `AuditAction` constants for 24 event types, `LogForwardingService` for external SIEM push.

5. Test Plan & Coverage

`mvn verify` builds **343 @Test methods across 35 test classes** (up from 97 / 15 at the end of Sprint 1). JaCoCo reports HTML + XML to `target/site/jacoco/` for SonarCloud ingestion.

Test class	Tests	Layer covered
<code>auth/AuthServiceTest</code>	21	Register, login, logout, password reset, password history, reset failures, 2FA flow
<code>auth/AccountLockoutIntegrationTest</code>	2	End-to-end account-locked-until-admin
<code>auth/PasswordResetIntegrationTest</code>	7	Reset request → token → confirm; expiry; reuse
<code>auth/api/AuthControllerTest</code>	12	MockMvc on <code>/api/auth/**</code> (register, login, 2FA, logout)
<code>auth/application/BackupCodeServiceTest</code>	6	2FA backup code generation, single-use verification
<code>auth/application/TotpServiceTest</code>	10	TOTP secret + QR code + code window
<code>user/UserServiceTest</code>	16	CRUD, IDOR (<code>update</code> , <code>findById</code>), role updates, soft delete, admin audit, session invalidation
<code>user/AdminUserServiceTest</code>	3	Admin reset password flow
<code>vault/VaultServiceTest</code>	8	CRUD + IDOR (<code>findById</code> , <code>delete</code>) + 50-per-user limit
<code>vault/api/VaultControllerTest</code>	13	MockMvc — RBAC, validation, 201/204/400/401
<code>credential/CredentialServiceTest</code>	11	CRUD, encryption, IDOR (3 paths), no-plaintext-in-response
<code>credential/CredentialIntegrationTest</code>	5	End-to-end encrypted persistence
<code>credential/api/CredentialControllerTest</code>	12	MockMvc — auth, validation, 201/204/400/401
<code>credential/api/CryptoMigrationControllerTest</code>	1	Re-encryption endpoint smoke test
<code>credential/application/CryptoMigrationServiceTest</code>	3	Migration from v1 → v2 keys
<code>trusteddevice/TrustedDeviceServiceTest</code>	6	Register, fingerprint collision, IDOR, revoke, rename
<code>filehandling/FileHandlingServiceTest</code>	6	Permissions, 3-pass wipe, path traversal, oversize, sanitised filename
<code>filehandling/CredentialImportExportServiceTest</code>	7	Empty payload, malformed lines, auto-vault, owner-not-found
<code>filehandling/ImportExportRateLimiterTest</code>	2	Token bucket — 5/min, per-principal isolation
<code>audit/api/AuditControllerTest</code>	8	RBAC — ADMIN/AUDITOR 200, USER 401; <code>my-login-history</code> endpoint
<code>audit/application/AuditServiceTest</code>	7	Hash chain, sanitization, IP/UA capture, sensitive log sanitization
<code>audit/application/LogForwardingServiceTest</code>	8	SIEM HTTPS push, failure modes
<code>audit/domain/AuditLogTest</code>	4	<code>@PreUpdate/@PreRemove</code> throw, <code>@PrePersist</code> timestamps
<code>shared/encryption/EncryptionServiceTest</code>	15	v1 / v2 roundtrip, tampering, short ciphertext, blank secret, key rotation fallback
<code>shared/security/JwtServiceTest</code>	12	Tampered, expired, garbage, wrong user, short secret, IP/UA binding, audience requirement
<code>shared/security/SecurityIntegrationTest</code>	21	End-to-end <code>SecurityFilterChain</code> , HSTS, CSP, frame-options, method allowlist
<code>shared/security/HmacAuthenticationFilterTest</code>	4	HMAC filter enable/disable, malformed signatures
<code>shared/security/HmacServiceTest</code>	2	HMAC compute / verify
<code>shared/security/CachedBodyHttpServletRequestTest</code>	1	Body caching wrapper
<code>shared/security/OutboundConnectionValidatorTest</code>	13	SSRF private-range / loopback / link-local rejection, allowlist
<code>shared/dataprotection/DataClassificationServiceTest</code>	36	Protection requirements per class, sanitization, compliance mappings
<code>shared/dataprotection/DataClassificationTest</code>	22	Enum behaviour, retention guidance
<code>shared/dataprotection/DataRetentionServiceTest</code>	16	Retention policy lookup, expiry calculation

Test class	Tests	Layer covered
<code>shared/dataprotection/SensitiveDataElementTest</code>	20	Classification lookup, GDPR mapping
<code>shared/email/EmailServiceTest</code>	3	Password reset email, 2FA email
Total	343	

5.1 Threat → Test traceability (R01–R20 from `Phase1/ThreatIdentification.md`)

Risk	Mitigation	Test evidence (Sprint 2 state)
R01	5 attempts → 15 min lockout	<code>AuthServiceTest.login_shouldLockAccount_afterMaxFailedAttempts</code> + <code>AccountLockoutIntegrationTest</code>
R02	HS256 + signature/exp/audience + IP/UA binding	<code>JwtServiceTest</code> (12) — tampered, garbage, wrong user, expired, short secret, IP mismatch, UA mismatch
R03	Argon2 + AES-256-GCM (PBKDF2 v2 KDF)	<code>EncryptionServiceTest</code> (15) + <code>CredentialServiceTest.create_shouldEncryptPasswordAndSave</code>
R04	DTO whitelist; <code>PATCH /role</code> is ADMIN-only	<code>UserServiceTest</code> + <code>AuthControllerTest</code>
R05	Vault-ownership check on every credential op	<code>CredentialServiceTest.create/findById/delete_shouldThrow_whenCredentialDoesNotBelongToOwner</code> (3)
R06	Generic exception messages; <code>EncryptionException</code>	<code>EncryptionServiceTest.decrypt_shouldThrow...</code> (3)
R07	Owner-scoped repository queries	<code>VaultServiceTest.findById/delete_shouldThrow_whenVaultDoesNotBelongToOwner</code>
R08	UUID rename + extension allowlist; 5 MiB cap → 413	<code>FileHandlingServiceTest.storeUpload_sanitisesFilename</code> + <code>storeUpload_shouldRejectOversizeFile</code>
R09	0700 dir + 0600 files	<code>FileHandlingServiceTest.exportCredentials_filesAreOwnerOnly</code>
R10	Export endpoint has no <code>vault_id</code>	n/a (impossible by design)
R11	<code>ImportExportRateLimiter</code> 5/min/principal → 429	<code>ImportExportRateLimiterTest.tryAcquireExport_allowsFivePerMinute_thenThrottles</code>
R12	3-pass wipe (2× random + zero)	<code>FileHandlingServiceTest.secureDelete_removesFileAndLogsSuccess</code>
R13	<code>verifyWithinTempDir</code> → <code>IllegalArgumentException</code>	<code>FileHandlingServiceTest.secureDelete_refusesPathOutsideTempDir</code>
R14	<code>AuditLog @PreUpdate / @PreRemove</code> throw	<code>AuditLogTest</code> + <code>AuditServiceTest.log_shouldBuildHashChain</code>
R15	CRLF / control chars stripped in <code>AuditService.sanitize</code>	<code>AuditServiceTest.log_shouldSanitizeDetails</code>
R16	Append-only DB writes; rate limits at auth + import/export	Load testing remains out of unit-test scope (k6/Gatling backlog)
R17	Fingerprint collision rejected with 403 + audit	<code>TrustedDeviceServiceTest.register_shouldRejectFingerprintOwnedByAnotherUser</code>
R18	<code>UserService.deleteById / updateUserRole</code> write audit	<code>UserServiceTest.deleteById_shouldSoftDeleteUser</code> , <code>updateUserRole_shouldChangeRoleAndSave</code>
R19	JWT expiry + export rate limit	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code> + R11 rate limit
R20	<code>SECURE_WIPE_FAILED</code> audit emitted before throw	<code>FileHandlingServiceTest.secureDelete_refusesPathOutsideTempDir</code>

Coverage: 17 Covered · 2 Design-immune · 1 Missing (R16 — load-test scope). Documented as remaining Sprint 3 backlog.

5.2 GR / UR traceability (from `Phase1/SecurityTestPlanV2.md`)

ID	Requirement	Sprint 2 evidence	Status
GR1	Auth + RBAC on all endpoints	<code>@PreAuthorize</code> per controller (<code>AuditController</code> , <code>UserController</code> , <code>AdminUserController</code> , <code>CredentialController</code> , <code>VaultController</code> , <code>TrustedDeviceController</code>); enforced by <code>SecurityConfig @EnableMethodSecurity</code>	Covered

ID	Requirement	Sprint 2 evidence	Status
GR2	Input validation & sanitization	DTO <code>@NotBlank/@Email/@Size</code> ; <code>AuditServiceTest.log_shouldSanitizeDetails</code> ; controller tests for 400; <code>PasswordValidator</code>	Covered
GR3	HTTPS / TLS	NGINX TLS 1.2/1.3 + HSTS + OCSP; mTLS to PostgreSQL; documented in <code>TLS_Architecture_Policy.md</code>	Architectural
GR4	Failed auth attempts logged	<code>AuthServiceTest — LOGIN_FAILED</code> audit on bad password and on logout	Covered
GR5	Rate limiting on sensitive endpoints	<code>AuthServiceTest.login_shouldLockAccount_...</code> + <code>ImportExportRateLimiterTest</code> (2) + reset-attempt limiter	Covered
GR6	Strong password hashing (Argon2)	<code>SecurityConfig.passwordEncoder()</code> returns <code>Argon2PasswordEncoder.defaultsForSpringSecurity_v5_8()</code> ; exercised in <code>AuthServiceTest</code>	Covered
GR7	JWT expiration validation	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code> (+ revocation list)	Covered
GR8	Credentials encrypted at rest	<code>CredentialServiceTest.create_shouldEncryptPasswordAndSave</code> + <code>EncryptionServiceTest</code> (15) + v2 PBKDF2 KDF	Covered
GR9	Secure wipe of temp files	<code>FileHandlingServiceTest.secureDelete_removesFileAndLogsSuccess</code> + <code>secureDelete_refusesPathOutsideTempDir</code>	Covered
GR10	Audit logs restricted to ADMIN / AUDITOR	<code>AuditControllerTest — ADMIN 200, AUDITOR 200, anon 401</code>	Covered
UR1	User only accesses own vaults / credentials / devices	<code>VaultServiceTest</code> , <code>CredentialServiceTest</code> , <code>TrustedDeviceServiceTest</code> , <code>UserServiceTest.update_shouldThrow_whenUserAttemptsToUpdateOtherUser</code>	Covered
UR2	Stored credentials encrypted	<code>CredentialServiceTest</code> + <code>EncryptionServiceTest</code>	Covered
UR3	Register trusted devices	<code>TrustedDeviceServiceTest.register_shouldCreateNewDevice...</code> + fingerprint-collision rejection	Covered
UR4	Import/export does not expose data	<code>CredentialImportExportServiceTest</code> (7) + <code>FileHandlingServiceTest</code> (6)	Covered
UR5	Log of important actions on user account	<code>CredentialServiceTest.delete_shouldDeleteAndAudit</code> , <code>VaultServiceTest.delete_shouldDeleteAndAudit</code> , <code>TrustedDeviceServiceTest.revoke_*</code>	Covered
UR6	Session expiration	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code> + 1 h absolute lifetime in <code>Session_Management_Policy.md</code>	Covered
UR7	Admin cannot access user credentials	No admin endpoint exposes decrypted passwords — architectural guarantee	Architectural
UR8	All administrative actions logged	<code>UserServiceTest.deleteById_shouldSoftDeleteUser</code> + <code>updateUserRole_shouldChangeRoleAndSave</code>	Covered
UR9	Auditor read-only on logs	<code>AuditController</code> is read-only; <code>AuditLog @PreUpdate/@PreRemove</code> block writes	Covered
UR10	Audit records immutable	<code>AuditLogTest</code> JPA lifecycle guards + <code>AuditServiceTest.log_shouldBuildHashChain</code>	Covered

6. Functional Surface (controllers & endpoints)

Pulled from `@PreAuthorize` and `@RequestMapping` declarations:

Bounded context	Service	Controller (api/)	Endpoints	@PreAuthorize
Auth	<code>AuthService</code> — register / login / logout / password reset / 2FA / TOTP / logout	<code>AuthController</code>	POST /api/auth/register, POST /api/auth/login, POST /api/auth/2fa/{verify,verify-backup-code,enable,disable}, POST /api/auth/totp/{setup,confirm,disable,verify}, POST /api/auth/logout	Public for register, login, 2fa/verify; authenticated for 2fa/enable, 2fa/disable, logout, TOTP
User	<code>UserService</code> — CRUD, role update,	<code>UserController</code>	GET /api/users, GET /api/users/{id}, PUT /api/users/{id}, DELETE /api/users/{id}, PATCH	ADMIN-only for list / role / activate /

Bounded context	Service	Controller (api/)	Endpoints	@PreAuthorize
	activate/deactivate, profile update, session termination		/api/users/{id}/role, PATCH /api/users/{id}/activate, POST /api/users/{id}/terminate-sessions, POST /api/users/terminate-all-sessions	terminate; ADMIN or USER (self) for GET /{id} and PUT /{id}
User (admin)	AdminUserService — admin-initiated password reset	AdminUserController	(class-level @PreAuthorize("hasRole('ADMIN')"))	ADMIN
Vault	VaultService — CRUD with ownership validation, 50-vault per-user cap	VaultController	POST /api/vaults, `GET /... (22 KB re... (1 KB restante(s))	